



GROUP ASSIGNMENT

COMP40002

**NETWORKING CONCEPTS AND CYBER SECURITY- 2
COM24A2**

CB014572, CB014583, CB014647

HAND OUT DATE: 24-Mar-25

HAND IN DATE: 13-Jun-25

WEIGHTAGE: ASSIGNMENT 1: 50%

INSTRUCTION TO CANDIDATES:

- 1. Students are advised to underpin their answers with the use of references (cited using the Harvard Name System of Referencing).**
- 2. Late submission will be awarded zero (0) unless Exceptional Circumstances (EC) are upheld.**
- 3. We draw your attention to the [Academic Conduct](#) Procedure to encourage good academic practice.**
- 4. Assignment presentation and modeling work should be submitted as a soft copy.**

1.0 Table of Contents

1.0 Table of Contents	2
2.0 Table of Figures	3
3.0 Acknowledgement.	4
4.0 Introduction.....	5
5.0 Reconnaissance.	6
5.1 The Role of Reconnaissance in Cyber Attacks.....	6
5.2 Domain Investigation Using WHOIS Lookup and DNS Query.....	7
5.2.1 WHOIS Lookup.	7
5.2.2 DNS Query.....	8
5.3 Analyzing Website Metadata for Information Retrieval and Optimization.....	9
5.4 Social Media Profiling for Publicly Available Organizational Intelligence.	14
5.5 Google Dorking for Info Gathering.	19
5.5.1 Google Dorking Applied to NSBM.	19
5.5.2 Security Implications.	22
6.0 Nmap Scan Results.	23
7.0 Risk Assessment.	25
7.1 Risk Assessment Using the OCTAVE Allegro Framework.	25
7.2 Analyzing Threats and Their Impacts.....	25
7.3 Evaluation of Risk Impact Areas.	26
7.4 Mitigation Plan.....	27
7.5 Allegro Worksheets	28
8.0 Quantitative Risk Assessment Using ALE & SLE	42
8.1 Phishing.....	42
8.2 Email Spoofing.	43
8.3 Website Exploitation.....	43
8.4 Credential theft via Google Dorking.....	44
8.5 Insider Threats.	44
8.6 Total Annual Loss Expectancy (ALE).....	45
9.0 Overall Assessment.....	46
10.0 References.....	47

2.0 Table of Figures

Figure 1 WHOIS Lookup Result.	7
Figure 2 DNS Query Result.	8
Figure 3 Metadata technologies identified using BuiltWith. (Analytics and Tracking)....	10
Figure 4 Metadata technologies identified using BuiltWith. (Frameworks)	10
Figure 5 Metadata technologies identified using BuiltWith. (JavaScript Libraries and Functions)	11
Figure 6 Metadata technologies identified using BuiltWith. (Web Hosting Providers)....	12
Figure 7 Metadata technologies identified using BuiltWith. (Email Hosting Providers & Web Servers).....	13
Figure 8 Instagram Public Post 2 from NSBM Official Account.	15
Figure 9 Instagram Public Post 1 from NSBM Official Account.....	15
Figure 10 Instagram Public Post 3 from NSBM Official Account.	16
Figure 11 LinkedIn Alumni Post 1 from NSBM Official Account.	17
Figure 12 LinkedIn Alumni Post 2 from NSBM Official Account.	18
Figure 13 Online Payment Portal.....	20
Figure 14 Learning Management System (LMS) Login Page.....	20
Figure 15 Online Servies & Examinations Portals.	21
Figure 16 Carrer Guidance Portal.	21
Figure 17 Nmap Scan Results 1.....	23
Figure 18 Nmap Scan Results 2.....	23
Figure 19 Nmap Scan Results 3.....	24
Figure 20 Nmap Scan Results 4.....	24
Figure 21 Analyzing Threats and Their Impacts.	25

3.0 Acknowledgement.

The group wishes to extend sincere appreciation to Ms. Fathima Naisar for her unceasing support, guidance, and firm encouragement during the undertaking of this cybersecurity assignment. Her lectures and feedback greatly improved the group's understanding of the core concepts of cybersecurity, which aided in the successful compilation of the report.

4.0 Introduction.

The complexity and frequency of cyberthreats have increased in the modern digital environment, especially since artificial intelligence (AI) has been incorporated into cybercrime. Even well-secured organizations are vulnerable to cyber intrusions because artificial intelligence (AI) is now being used to automate attacks, create misleading phishing content, and find system vulnerabilities at a never-before-seen speed (Lindiwe Matlali, 2023).

The first part of this study centers on the passive reconnaissance of NSBM Green University, a well-known Sri Lankan university. Using tools including Google Dorking, WHOIS searches, DNS searches, social media profiling, and website metadata analysis, this stage entails gathering publicly available information. These methods seek to find exposed data and possible weaknesses without directly touching or influencing university systems.

The report then moves on to a comprehensive risk assessment and the application of a cybersecurity framework. This entails examining the dangers found during reconnaissance, calculating their impact using quantitative techniques, and utilizing an appropriate industry-standard framework, like ISO/IEC 27001 or the NIST Cybersecurity Framework. These frameworks offer methodical recommendations for enhancing the cybersecurity resilience of the university.

This project mainly aims to assist NSBM Green University in identifying and reducing possible cyber risks by means of ethical and strategic use of all acquired data. This evaluation not only underlines the need for cyber hygiene in learning settings but also offers practical suggestions to enable NSBM to lower the cybercrime risk and improve its digital defenses.

5.0 Reconnaissance.

5.1 The Role of Reconnaissance in Cyber Attacks.

Reconnaissance is the very first phase of an attack or defensive evaluation in the field of cybersecurity. In order to identify potential weak points, it entails obtaining intelligence about the target's systems, networks, or general structure. This phase is essential for creating a comprehensive picture of the target's cybersecurity posture and directing subsequent actions, whether they be defensive or offensive (Anon., 2025).

Passive and active are the two categories that reconnaissance techniques are typically divided.

Passive reconnaissance - Using resources like WHOIS, DNS lookups, or data from websites and social media therefore, passive reconnaissance is the process of gathering information without speaking to the target.

Active reconnaissance - However, active reconnaissance increases the potential of detection by directly probing the target, as in port scans.

5.2 Domain Investigation Using WHOIS Lookup and DNS Query.

5.2.1 WHOIS Lookup.

To get the domain registration information for the official NSBM University website (nsbm.ac.lk), a WHOIS lookup was performed. The domain is active and registered under Sri Lanka's **ac.lk** academic top-level domain, according to the lookup. There were found to be two authoritative name servers:

- ns.nsbm.ac.lk
- ns1.ac.lk

The IP address **3.86.174.106**, hosted by **Amazon Data Services** in **Ashburn, Virginia, USA (ASN: AS14618)**, is where the domain resolves. This implies that NSBM makes use of cloud hosting, which improves scalability and dependability.

In accordance with local registry policies under .lk, where such information is not disclosed in standard WHOIS outputs, the WHOIS records did not disclose ownership or registrant details.

DomainTools PROFILE CONNECT MONITOR SUPPORT Whois Lookup LOGIN Sign Up

Home > Whois Lookup > Nsbm.ac.lk Notice: Possible deprecation of Whois services after January 28, 2025. More Info

Whois Record for Nsbm.ac.lk

How does this work?

Domain Profile

Registrar Status	taken
Name Servers	NS.NSBM.AC.LK (has 1 domains) NS1.AC.LK (has 16 domains)
IP Address	3.86.174.106 is hosted on a dedicated server
IP Location	🇺🇸 - Virginia - Ashburn - Amazon Data Services Nova
ASN	🇺🇸 AS14618 AMAZON-AES, US (registered Nov 04, 2005)
IP History	2 changes on 2 unique IP addresses over 3 years
Hosting History	5 changes on 3 unique name servers over 3 years

Whois Record (last updated on 2025-05-17)

```
% NOTE: The registry for this domain name does not publish ownership
% records (whois records) in the standard format. This data
% represents the most likely status of the domain based on
% information provided by the Internet's domain name servers (DNS).

domain: nsbm.ac.lk
status: taken
nameserver: ns.nsbm.ac.lk
nameserver: ns1.ac.lk

% For more information, please visit http://www.domains.lk/
```

DomainTools Iris
The gold-standard Internet intelligence platform
Learn More

Preview the Full Domain Report

Tools

- Hosting History
- Monitor Domain Properties
- Reverse IP Address Lookup
- Network Tools
- Visit Website

View Screenshot History

Available TLDs

General TLDs Country TLDs

Figure 1 WHOIS Lookup Result.

5.2.2 DNS Query.

The domain's publicly available DNS records were examined using a DNS query. The following was the response from Cloudflare's DNS resolver:

- **IPv4 Address: 3.86.174.106**
- **Hosting Provider: Amazon.com, Inc.**
- **TTL: 1 hour (record cache time)**

Additional DNS Results:

- No IPv6 address (AAAA record) could be located.
- CNAME Record: There isn't one.
- TXT Record: No TXT records were discovered, indicating that DNS-level email security settings like SPF or DKIM are not present.

➤ **This shows that although the NSBM website is hosted on AWS infrastructure with standard A records, it does not yet have some DNS-level configurations that could enhance performance and security.**

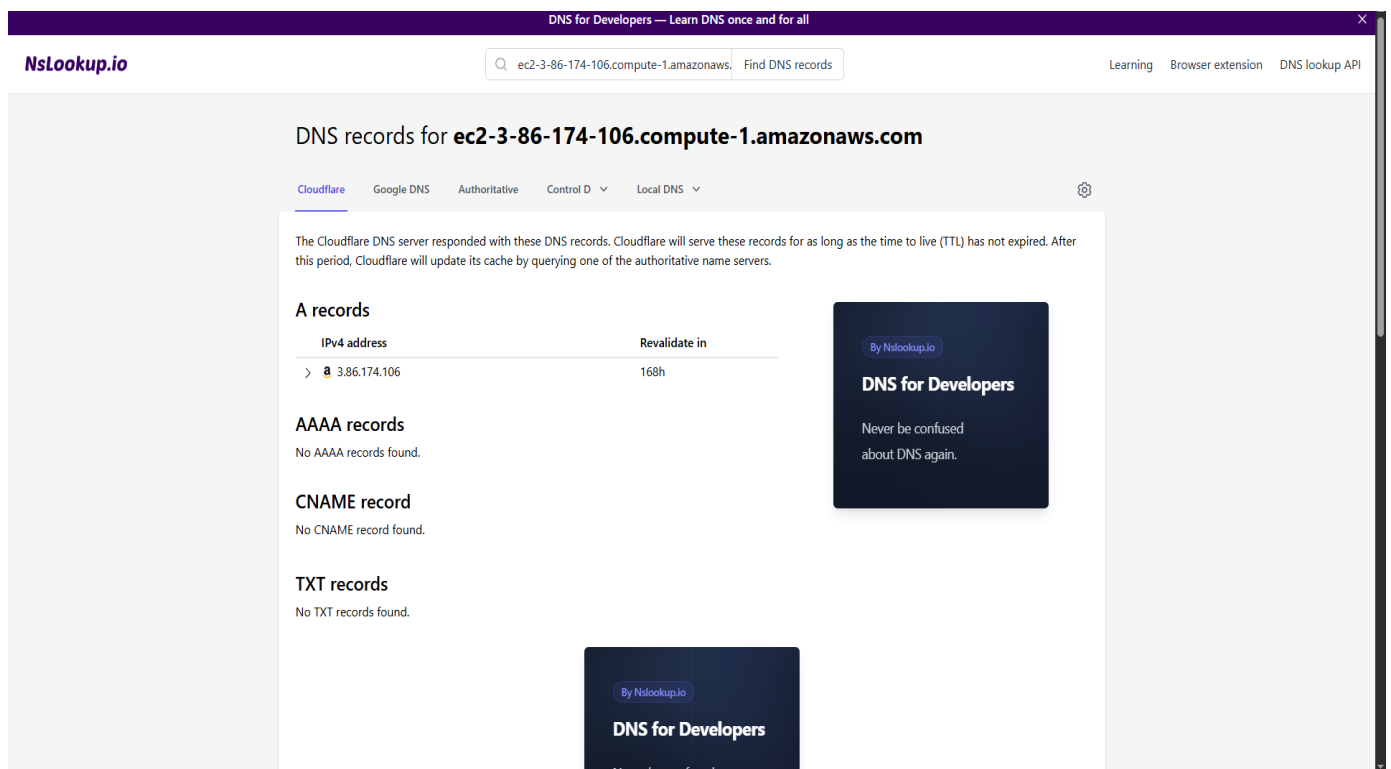


Figure 2 DNS Query Result.

- ❖ Important infrastructure components like the hosting location, DNS setup, and name servers were discovered during the WHOIS and DNS reconnaissance carried out on NSBM. These specifics serve as a baseline for additional vulnerability assessment and aid in locating possible exposure points in systems that are visible to the public.

5.3 Analyzing Website Metadata for Information Retrieval and Optimization.

Using tools like BuiltWith and browser developer tools, a passive metadata analysis was carried out to evaluate the NSBM website (<https://www.nsbm.ac.lk>). Without having to deal with the system directly, this technique assists in identifying the underlying technologies, configurations, and components that are operating on a website.

The content management system (CMS), JavaScript libraries, server type, analytics tools, and security features are examples of elements that are included in website metadata. Although these details are intended to improve site performance and SEO, they may also inadvertently provide cybercriminals with information they can use. In addition to increasing search engine visibility, website metadata can reveal information about a website's structure and technologies, which makes it vulnerable to cyberattacks if it is out-of-date or incorrectly configured, according to (Melissa Hawkins, n.d.).

The following technologies were found when the NSBM website was reviewed:

- Hosting Provider: **Amazon Web Services (AWS), Virginia, USA**
- CMS: **WordPress**
- Security Layer: **Cloudflare**
- JavaScript Frameworks: **jQuery**
- Analytics Tools: **Google Analytics**
- Server Information: **Likely Apache or Nginx (based on HTTP headers)**

Log In · Signup for Free

builtwith Tools ▾ Features ▾ Plans Customers Resources ▾ Website, Tech, Keyword **Lookup**

Home / nsbm.ac.lk Technology Profile

NSBM.AC.LK

Technology Profile Detailed Meta Products Performance Relationship Redirect AI Recommendations Company

Analytics and Tracking

[View Global Trends](#)

Global Site Tag
[Global Site Tag Usage Statistics · Download List of All Websites using Global Site Tag](#)
 Google's primary tag for Google Measurement/Conversion Tracking, Adwords and DoubleClick.

Google Analytics
[Google Analytics Usage Statistics · Download List of All Websites using Google Analytics](#)
 Google Analytics offers a host of compelling features and benefits for everyone from senior executives and advertising and marketing professionals to site owners and content developers.
 Application Performance · Audience Measurement · Visitor Count Tracking

Google Universal Analytics
[Google Universal Analytics Usage Statistics · Download List of All Websites using Google Universal Analytics](#)
 The analytics.js JavaScript snippet is a new way to measure how users interact with your website. It is similar to the previous Google tracking code, ga.js, but offers more flexibility for developers to customize their implementations.

Google Analytics 4
[Google Analytics 4 Usage Statistics · Download List of All Websites using Google Analytics 4](#)
 Google Analytics 4 formerly known as App + Web is a new version of Google Analytics that was released in October 2020.

Profile Details

[Change Layout](#)

Last technology detected on 16th May 2025.
 We know of 97 technologies on this page and 52 technologies removed from nsbm.ac.lk since 25th August 2019. [Link to this page.](#)

Add BuiltWith to Chrome for free! Get lookups easily and quickly.
[Add to Chrome](#)

Get a notification when nsbm.ac.lk adds new technologies.
[Create Notification](#)

Recent Lookups

igbcapital.com	theingredienthouse.co..
tailvest.com	puresalon.nl
maximumqualityfoods..	nwwfonlineauction.com
cityinfo.dk	musicboxsd.com
alrosavilla.com	developlearing.co.nz
developmint.co	ehsaneco.com
citykirana.com	thehitchhouse.com
clcgroningen.nl	jimmymsmithson.com
zaymkir.ru	jonesie.fr

Widgets

[View Global Trends](#)

WPForms
[WPForms Usage Statistics · Download List of All Websites using WPForms](#)
 WPForms is a popular drag & drop WordPress form builder.
 Feedback Forms and Surveys · WordPress Plugins

Figure 3 Metadata technologies identified using BuiltWith. (Analytics and Tracking)

[View Global Trends](#)

Frameworks

RadiusTheme
[RadiusTheme Usage Statistics · Download List of All Websites using RadiusTheme](#)
 RadiusTheme offers top-quality WordPress themes and plugins for your website needs. Find your ideal design and functionality from our collection.
 WordPress Theme

PHP
[PHP Usage Statistics · Download List of All Websites using PHP](#)
 PHP is a widely used general-purpose scripting language that is especially suited for Web development and can be embedded into HTML.

PHP 7
[PHP 7 Usage Statistics · Download List of All Websites using PHP 7](#)
 Version 7 of the PHP framework.

Organization Schema
[Organization Schema Usage Statistics · Download List of All Websites using Organization Schema](#)
 Organization i.e. school, NGO, Corporation.
 Schema

Eikra Theme
[Eikra Theme Usage Statistics · Download List of All Websites using Eikra Theme](#)
 Education WordPress Theme.
 WordPress Theme

Figure 4 Metadata technologies identified using BuiltWith. (Frameworks)

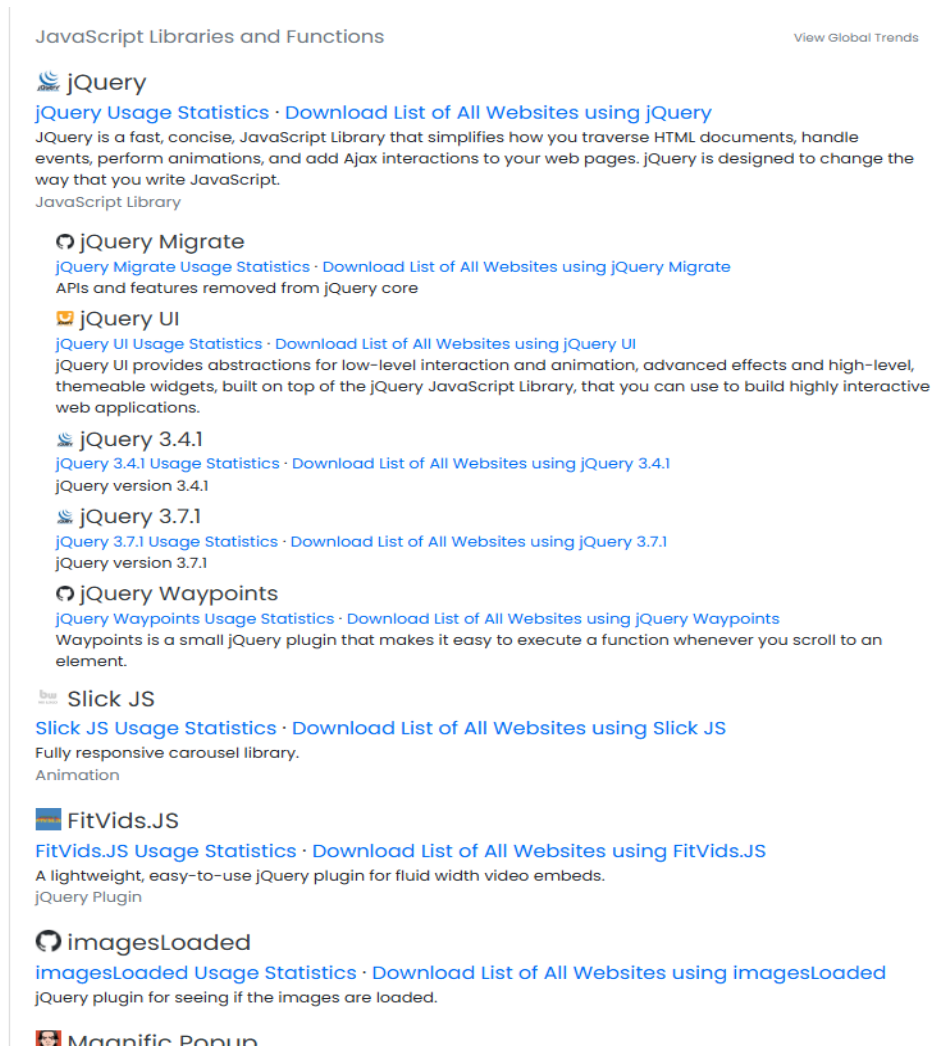


Figure 5 Metadata technologies identified using BuiltWith. (JavaScript Libraries and Functions)

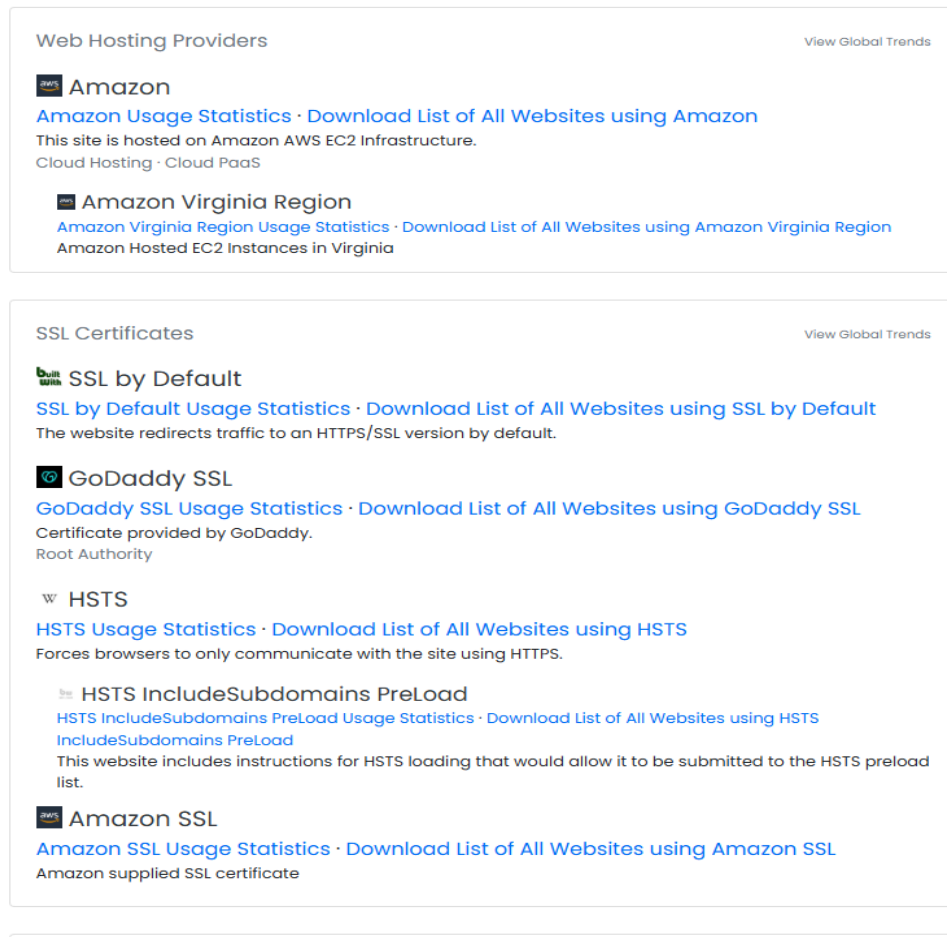


Figure 6 Metadata technologies identified using BuiltWith. (Web Hosting Providers)

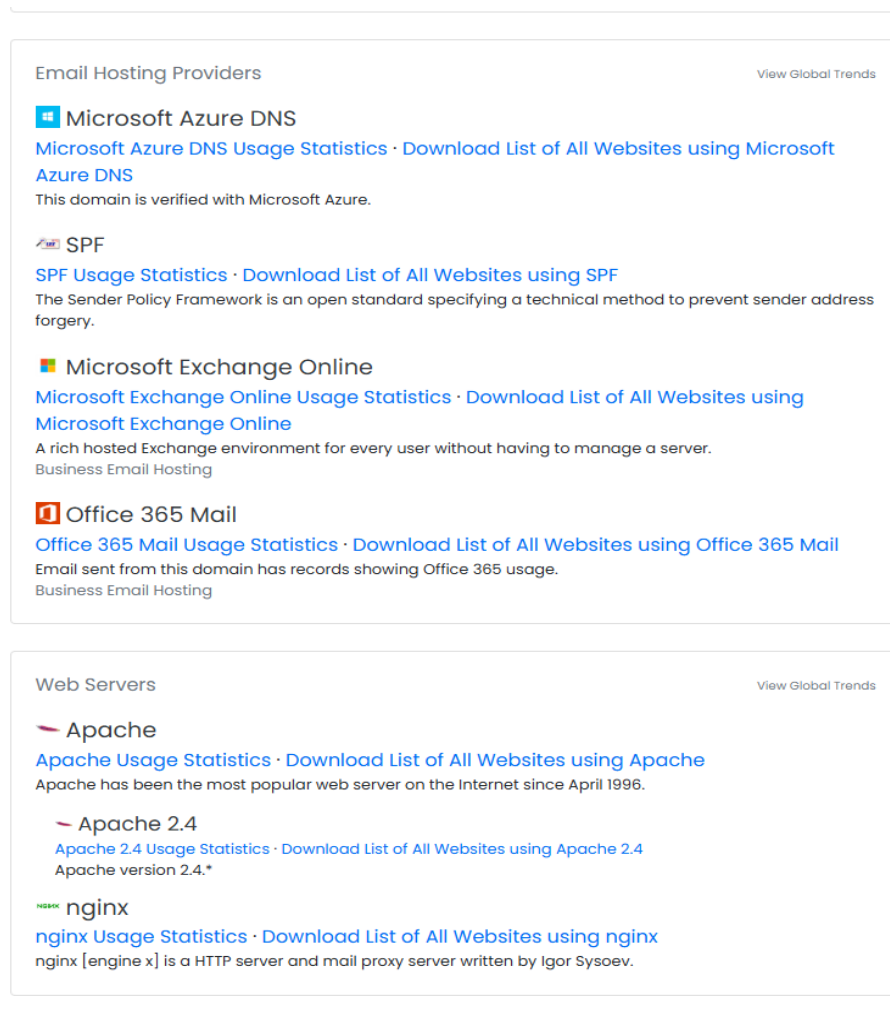


Figure 7 Metadata technologies identified using BuiltWith. (Email Hosting Providers & Web Servers)

5.4 Social Media Profiling for Publicly Available Organizational Intelligence.

A type of passive reconnaissance known as social media profiling entails obtaining information from publicly available sources on websites like Facebook, Instagram, and LinkedIn. The structure, important individuals, and possible security flaws exposed by employee behavior and institutional updates are all identified by cybersecurity experts using this technique.

An examination of NSBM's official and affiliated social media accounts was carried out. The actions listed below were taken:

- **LinkedIn Analysis:** No current job titles or employee profiles that were directly connected to NSBM were discovered during our LinkedIn reconnaissance. Nonetheless, several NSBM alumni profiles that highlighted their educational background and present employment status were accessible. This still provides insightful information about the university's standing industry, academic reach, and relationships with outside organizations.
 - **Facebook and Instagram Monitoring:** Regular updates regarding campus activities, academic calendars, and public engagements were posted on NSBM's official Facebook and Instagram pages. Such content may unintentionally reveal scheduling patterns or security procedures, even though it fosters community interaction.
 - **Risk Implication:** Malevolent actors may use social media to spear-phish or social engineer employees by displaying their roles and schedules. Public postings that reveal personnel information or internal operations can help develop focused attack plans.
- Threat actors regularly utilize employee social media content to create phishing campaigns or impersonation attacks, according to (Zehra Ali, 2023), highlighting the necessity for businesses to control both employee and corporate digital exposure.

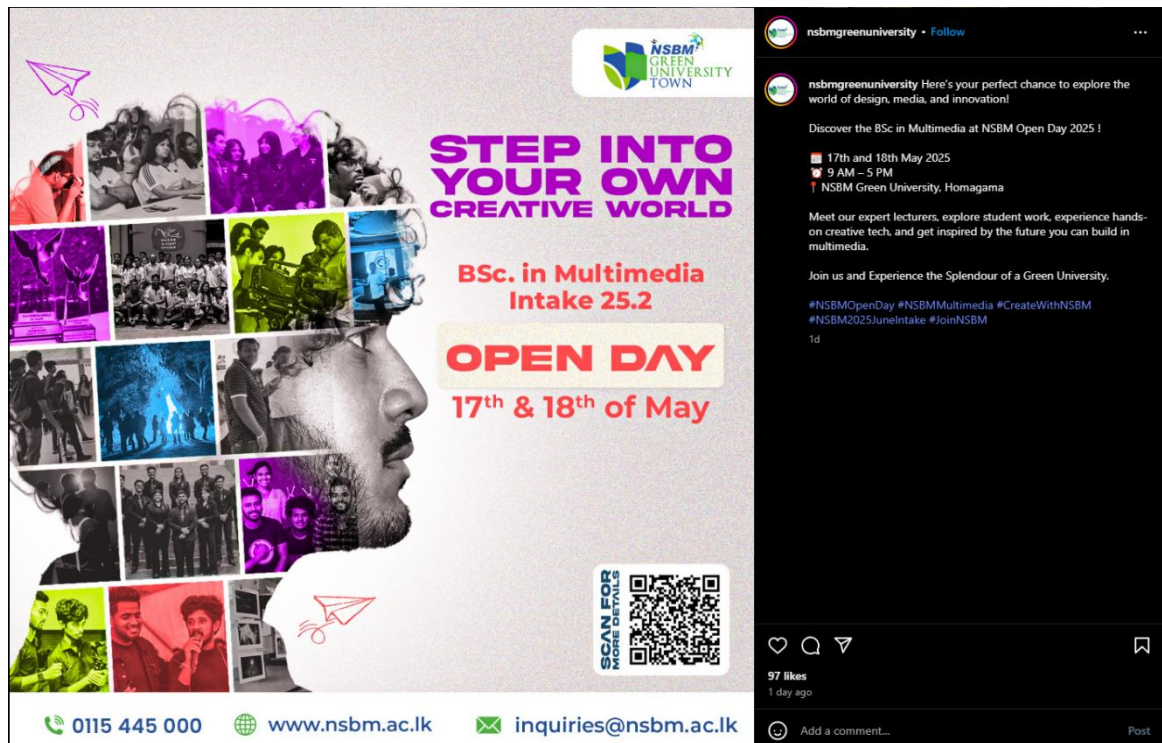


Figure 9 Instagram Public Post 1 from NSBM Official Account



Figure 8 Instagram Public Post 2 from NSBM Official Account.



PLYMOUTH UNIVERSITY

INTERNATIONAL SUMMER SCHOOL PROGRAMME - 2025

FROM 5TH JULY TO 20TH JULY AT UNIVERSITY OF PLYMOUTH, UK

5 SEATS LEFT!!

OPEN FOR ALL 18+ UNDERGRADUATES OF NSBM

Experience two weeks of learning, adventure, and cultural exploration at the University of Plymouth's International Summer School! Engage in group work and lectures, discover new subjects, and immerse yourself in the UK's rich culture and heritage.

THE PROGRAMME

Taught by Plymouth's academics and industry specialists with incredible international lecturing experience, students will gain an insight into leadership, entrepreneurship and cross-culture communication and technology. Explore strategic and cultural issues in depth.

WHY CHOOSE THE PROGRAMME?

- Improve your English: Conversational English in real world situations
- Meet new people: meet people from all around the world
- Enjoy Plymouth and the South West: our programme allows you to explore and enjoy the South West region during your time with us.
- Explore London with us during your final weekend

IMPORTANT

- You must confirm your participation for International summer school programme **AS SOON AS POSSIBLE**
- Details on your Investment, Visa Application Process, Flight Booking / Air Fare could be obtained from Contact persons

NSBM CAREER GUIDANCE UNIT
Telephone : +94 71 672 6007
Email : careerguidance@nsbm.ac.lk

MS. SHEHANI JOSEPH
Telephone : +94 77 522 9695
Email : shehani.j@nsbm.ac.lk

nsbmgreenuniversity · Follow

Ready for a Summer to Remember? Join the Plymouth University International Summer School – 2025 and experience two unforgettable weeks of learning, adventure, and cultural exploration in the UK!

📅 5th – 20th July 2025
📍 University of Plymouth, UK
🔥 Only 5 seats left – open to all NSBM undergraduates aged 18+!

- ◆ Sharpen your leadership and communication skills
- ◆ Network with students from around the world
- ◆ Explore London & the South West
- ◆ Boost your English in real-world settings

📌 Register Now: <https://forms.office.com/r/cBssRTJGrK>

Don't miss your chance – confirm your spot today! ⭐

#NSBM #PlymouthUniversity #InternationalSummerSchool #StudyAbroad #NSBMGoesGlobal #StudentExchange #UK2025

2d

119 likes
2 days ago

Add a comment... Post

Figure 10 Instagram Public Post 3 from NSBM Official Account.

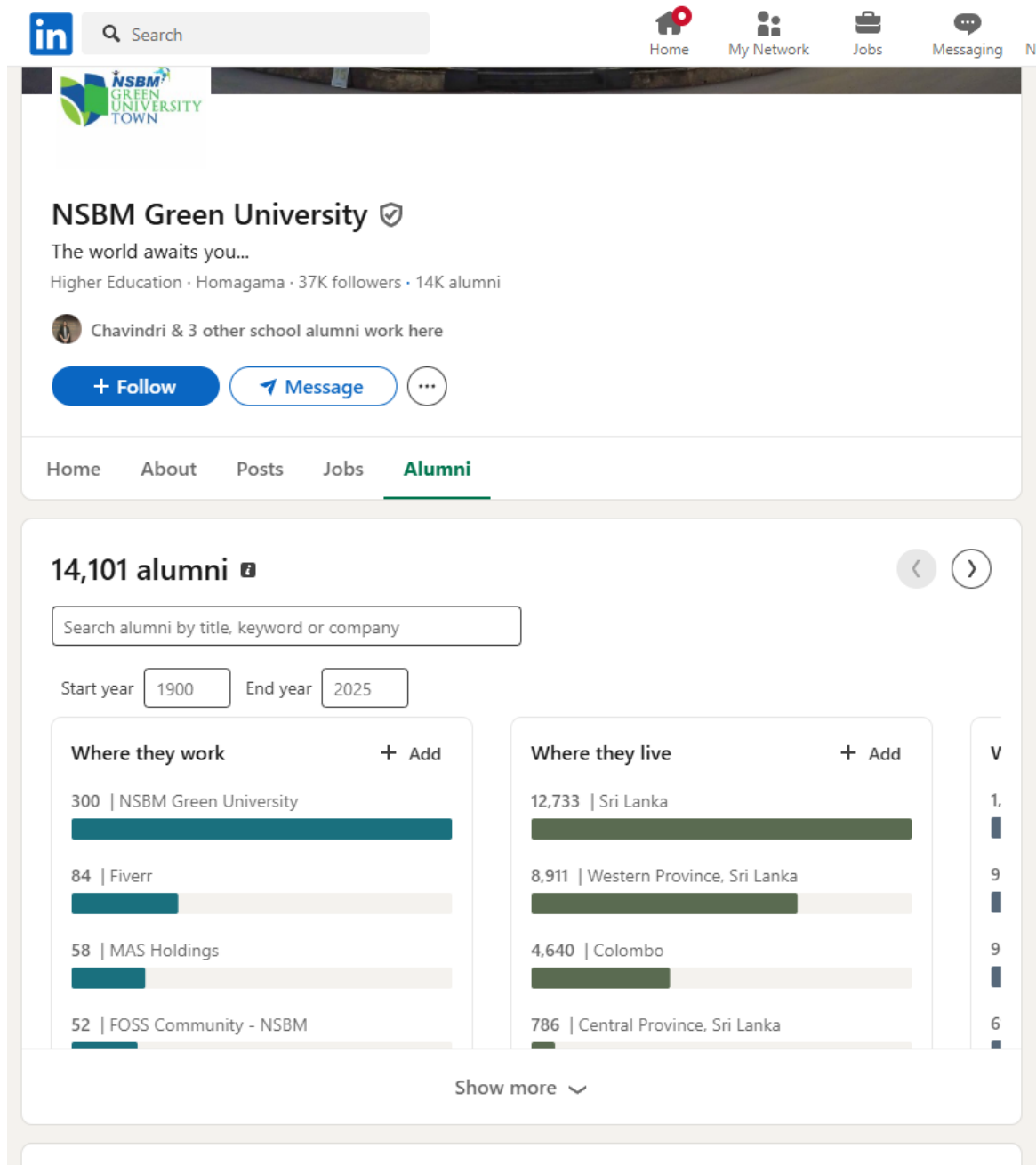


Figure 11 LinkedIn Alumni Post 1 from NSBM Official Account.

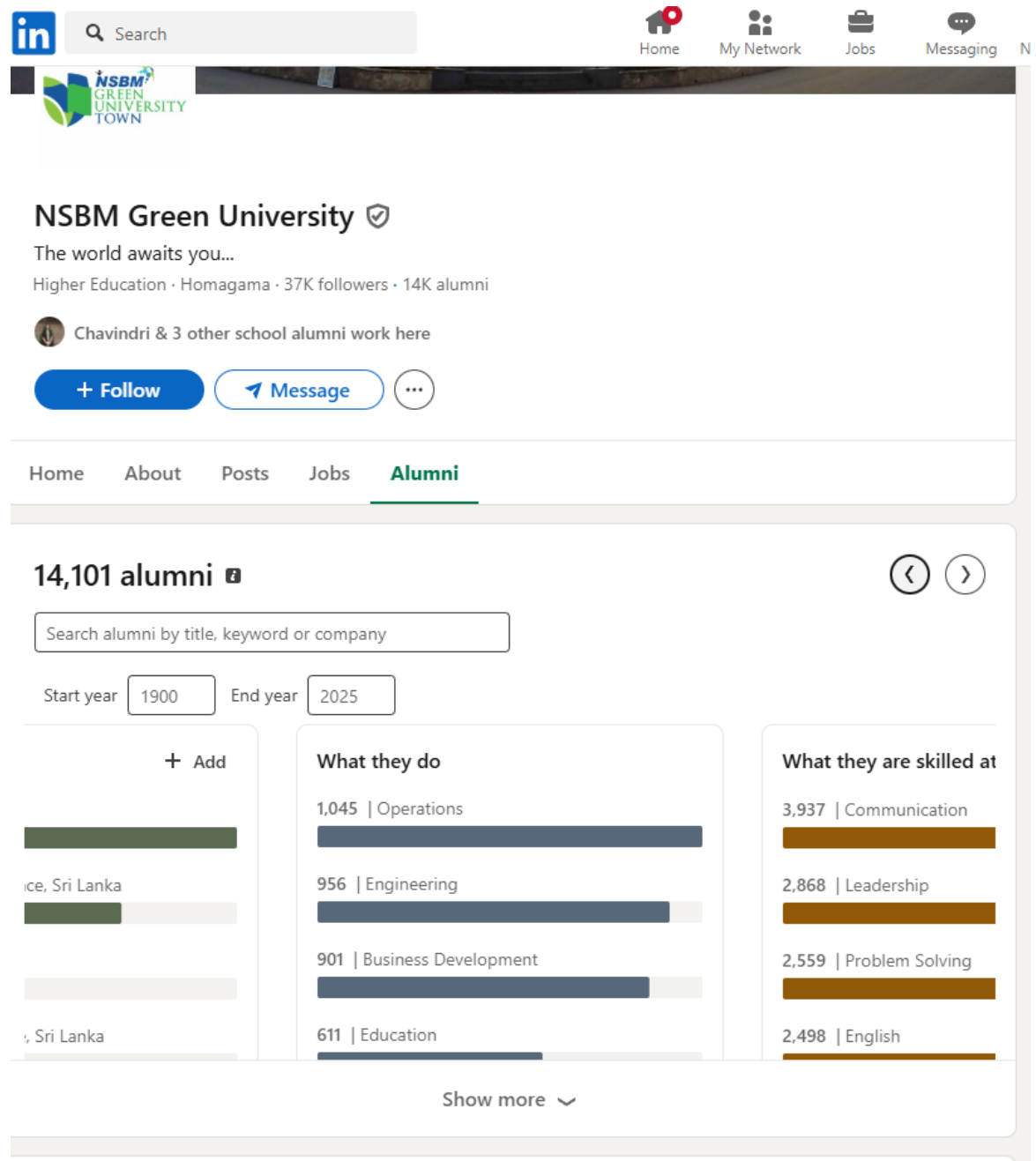


Figure 12 LinkedIn Alumni Post 2 from NSBM Official Account.

5.5 Google Dorking for Info Gathering.

Google Dorking, sometimes referred to as Google hacking, is a reconnaissance technique that uses sophisticated search queries to find hidden or sensitive information that is publicly available online. Attackers or security researchers can find login pages, internal documents, exposed directories, or unprotected systems that search engines inadvertently index by employing particular search operators (Alanna Titterington, 2025).

Instead of breaking into systems or gaining unauthorized access, this method uses search engines like Google's indexing capabilities to display results that could be dangerous if made public.

5.5.1 Google Dorking Applied to NSBM.

Several Google Dorking queries were used during the NSBM reconnaissance phase to find publicly accessible pages and services that a threat actor or cybersecurity analyst might find interesting. Finding exposed services without trying to access or communicate with them is the aim here.

The following NSBM-related services that can be accessed through a Google search were screenshotted:

- Learning Management Systems (LMS) are websites that make it easier to access course materials and engage in academic activities.
- Online services for students include pages where they can check their academic progress, schedules, and other information.
- Online Payment Portal: A way to pay for services or tuition.
- Career Guidance Portals are websites that list job placement opportunities and career services.
- Exam portals are web-based interfaces for tests and evaluations in academia.



Welcome to NSBM Green University

Login in. To see it in action.

Username

Password

Login

Figure 14 Learning Management System (LMS) Login Page.



Pay Online



Online Payment

Enter your Student ID and verify details.

Student's NSBM ID No / Reference No:

Enter Student ID

☐ I'm not a robot



reCAPTCHA
Privacy - Terms

SEARCH

Order No :

Name :

Intake :

Degree :

Fee Type :

Amount :

0

Currency :

I KR

Figure 13 Online Payment Portal.

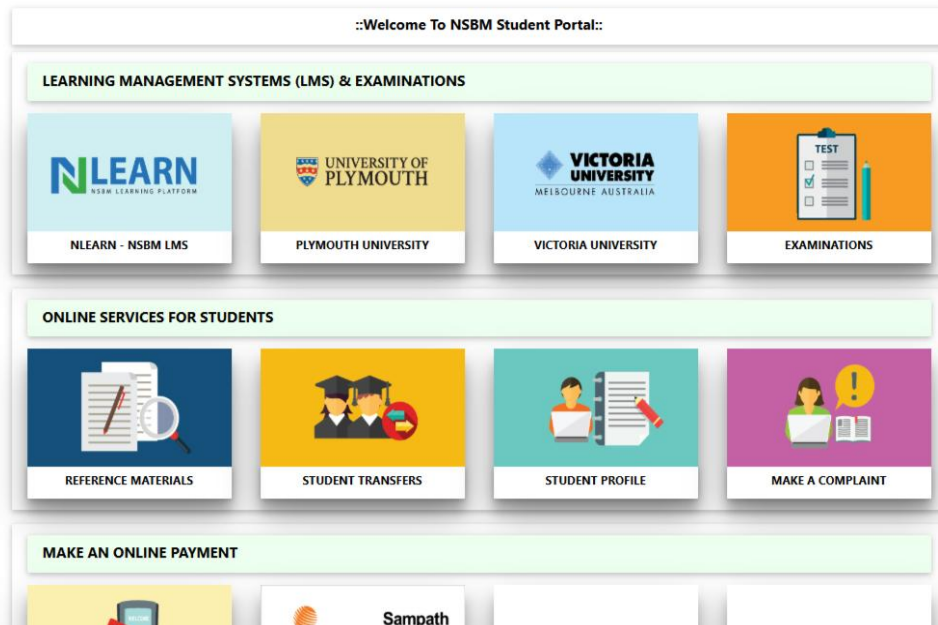


Figure 15 Online Services & Examinations Portals.

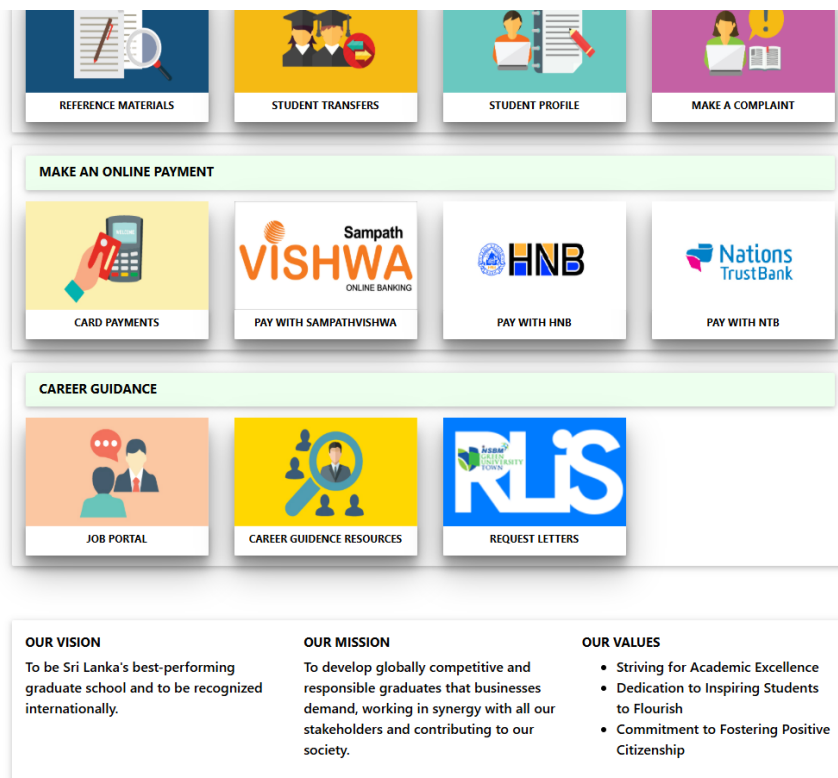


Figure 16 Career Guidance Portal.

All of these URLs can be found using standard Google search methods, including:

- **site:nsbm.ac.lk inurl:login**
- **site:nsbm.ac.lk intitle:"online payment"**
- **site:nsbm.ac.lk "LMS"**
- **site:nsbm.ac.lk "student portal"**

5.5.2 Security Implications.

The fact that these services appear in public search results emphasizes how crucial access controls and search engine visibility management are. Even if these portals are secure, the organization's attack surface is increased by their discoverability through Dorking.

Companies like NSBM must keep an eye on which areas of their infrastructure are publicly indexed. They must also make sure that sensitive endpoints are either excluded or protected using CAPTCHA, robots.txt, or appropriate login enforcement to prevent automated access.

6.0 Nmap Scan Results.

```

kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

root@kali: ~
File Actions Edit View Help

root@kali:~# nmap -sP 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:27 EDT
Nmap scan report for ec2-3-86-174-106.compute-1.amazonaws.com (3.86.174.106)
Host is up (0.14s latency).
Nmap done: 1 IP address (1 host up) scanned in 0.50 seconds

root@kali:~# nmap -sP 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:30 EDT
Nmap scan report for ec2-3-86-174-106.compute-1.amazonaws.com (3.86.174.106)
Host is up (0.0045s latency).
Not shown: 51074 filtered tcp ports (net-unreach), 14457 filtered tcp ports (
no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
113/tcp   closed ident
443/tcp   open  https
8080/tcp   open  http
Nmap done: 1 IP address (1 host up) scanned in 154.71 seconds

root@kali:~# nmap -p 25 -v 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:45 EDT
Initiating Ping Scan at 00:45
Scanning 3.86.174.106 [4 ports]
Completed Ping Scan at 00:45, 0.18s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 00:45
Completed Parallel DNS resolution of 1 host. at 00:45, 13.04s elapsed
Initiating SYN Stealth Scan at 00:45
Scanning 3.86.174.106 [1 port]
Completed SYN Stealth Scan at 00:45, 0.02s elapsed (1 total ports)
Nmap scan report for 3.86.174.106
Host is up (0.14s latency).
PORT      STATE SERVICE
25/tcp    filtered smtp
Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 13.33 seconds
Raw packets sent: 5 (1968) | Rcvd: 4 (2408)

root@kali:~# nmap -sT 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:47 EDT
Nmap scan report for 3.86.174.106
Host is up (0.00045s latency).
All 1000 scanned ports on 3.86.174.106 are in ignored states.
Not shown: 1000 filtered tcp ports (net-unreach)
Nmap done: 1 IP address (1 host up) scanned in 13.32 seconds

```

Figure 17 Nmap Scan Results 1.

```

kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

root@kali: ~
File Actions Edit View Help

root@kali:~# nmap -sS -A -O 3.86.174.106 -p 25
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:49 EDT
Nmap scan report for 3.86.174.106
Host is up (0.0013s latency).
PORT      STATE SERVICE VERSION
25/tcp    filtered smtp
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Aggressive OS guesses: 3Com 4500G switch (92%), H3C Comware 5.20 (92%), Huawei
VRP 8.100 (92%), Microsoft Windows Server 2003 SP1 (92%), Oracle VirtualBox
Slip NAT bridge (92%), QEMU user mode network gateway (92%), AXIS 2100 Netw
ork Camera (92%), D-Link DP-300U, DP-G310, or Hamlet HP3010U print server (92
%), HP True64 UNIX v.1A (92%), Sanyo PLC-KX08 digital video projector (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1  1.76 ms 3.86.174.106
OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.85 seconds

root@kali:~# nmap -sU 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:51 EDT
Nmap scan report for 3.86.174.106
Host is up (0.00077s latency).
All 1000 scanned ports on 3.86.174.106 are in ignored states.
Not shown: 1000 filtered udp ports (net-unreach)
Nmap done: 1 IP address (1 host up) scanned in 13.34 seconds

root@kali:~# nmap -TS 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:52 EDT
Nmap scan report for 3.86.174.106
Host is up (0.0010s latency).
All 1000 scanned ports on 3.86.174.106 are in ignored states.
Not shown: 1000 filtered tcp ports (net-unreach)
Nmap done: 1 IP address (1 host up) scanned in 13.30 seconds

root@kali:~# nmap -p 25 --script=smb-vuln3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:57 EDT
Nmap scan report for 3.86.174.106
Host is up (0.00077s latency).
NSE: failed to initialize the script engine:
/usr/share/nmap/nse_main.lua:829: 'smb-vuln3.86.174.106' did not match a cat
egory, filename, or directory
stack traceback:

```

Figure 18 Nmap Scan Results 2.

```

kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

root@kali: ~
Nmap done: 1 IP address (1 host up) scanned in 13.34 seconds

(root@kali) ~
nmap -T5 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:52 EDT
Nmap scan report for 3.86.174.106
Host is up (0.0010s latency).
All 1000 scanned ports on 3.86.174.106 are in ignored states.
Not shown: 1000 filtered tcp ports (net-unreach)

Nmap done: 1 IP address (1 host up) scanned in 13.30 seconds

(root@kali) ~
nmap -p 25 --script=smb-vuln* 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 00:57 EDT
NSE: failed to initialize the script engines
/usr/share/nmap/nse_main.lua:829: 'smb-vuln*3.86.174.106' did not match a cat
egory, filename, or directory
stack traceback:
  [C]: in function 'error'
  /usr/share/nmap/nse_main.lua:829: in local 'get_chosen_scripts'
  /usr/share/nmap/nse_main.lua:1364: in main chunk
  [C]: in ?

QUITTING!

(root@kali) ~
nmap -sU -p 161 --script=snmp-interfaces 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 01:01 EDT
Nmap scan report for 3.86.174.106
Host is up (0.0012s latency).

PORT      STATE SERVICE
161/udp   filtered snmp

Nmap done: 1 IP address (1 host up) scanned in 13.36 seconds

(root@kali) ~

```

Figure 19 Nmap Scan Results 3.

```

kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

root@kali: ~
[C]: in ?

QUITTING!

(root@kali) ~
nmap -sU -p 161 --script=snmp-interfaces 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 01:01 EDT
Nmap scan report for 3.86.174.106
Host is up (0.0012s latency).

PORT      STATE SERVICE
161/udp   filtered snmp

Nmap done: 1 IP address (1 host up) scanned in 13.36 seconds

(root@kali) ~
nmap -T5 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 01:27 EDT
Nmap scan report for 3.86.174.106
Host is up (0.0012s latency).
All 1000 scanned ports on 3.86.174.106 are in ignored states.
Not shown: 1000 filtered tcp ports (net-unreach)

Nmap done: 1 IP address (1 host up) scanned in 13.91 seconds

(root@kali) ~
nmap -T3 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 01:28 EDT
Nmap scan report for 3.86.174.106
Host is up (0.0014s latency).
All 1000 scanned ports on 3.86.174.106 are in ignored states.
Not shown: 1000 filtered tcp ports (net-unreach)

Nmap done: 1 IP address (1 host up) scanned in 13.39 seconds

(root@kali) ~
nmap -T2 3.86.174.106
Command 'nmap' not found, did you mean:
  command 'nama' from deb nama
  command 'nmap' from deb nmap
  command 'pamp' from deb pamp
  command 'wamp' from deb python3-autobahn
  command 'nam' from deb nam
Try: apt install <deb name>

(root@kali) ~
nmap -T2 3.86.174.106
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-08 01:29 EDT

```

Figure 20 Nmap Scan Results 4.

7.0 Risk Assessment.

7.1 Risk Assessment Using the OCTAVE Allegro Framework.

It is a simple, yet effective method for assessing cybersecurity risks through assets. Its goal is to identify the most important information kept by the organization and to identify the possible threats against it. Applying the model helps NSBM look at cyber risks in a way that makes sense based on potential public harm and the ways the organization's operations might be impacted.

As a result of our reconnaissance and analysis of the threats, the following information assets are critical for NSBM:

- Student Information System (SIS)
- Online Payment Portal
- NSBM Learning Management System (LMS)
- Official NSBM Website (WordPress CMS)
- Staff Login Portals and Internal Communication Systems

7.2 Analyzing Threats and Their Impacts.

Asset	Threat	Potential Impact
Student Information System(SIS)	Phishing attacks using publicly available staff data (LinkedIn, Instagram)	Data breach, identity theft
Online Payment Portal	Searchable via Google Dorking	Financial data theft, fraud
LMS	Spoofing due to lack of DNS TXT records (SPF, DKIM)	Unauthorized access, impersonation
NSBM Website	Exploitation of visible WordPress metadata	Site defacement, information leakage
Staff Portals	Credential harvesting from exposed login pages	Unauthorized access, privilege escalation

Figure 21 Analyzing Threats and Their Impacts.

7.3 Evaluation of Risk Impact Areas.

Each scenario has been assessed using important business impact areas as a guide:

- There is a big chance that using LMS or SIS systems will cause them to slow down or malfunction because of attacks.
- Damage to reputation: Getting an organization's name or data out into the public can damage trust among stakeholders.
- Non-compliance with relevant laws, for example the Data Protection Act in Sri Lanka.
- Financial Loss: Scams or charges from violations on payment systems.

Asset	Risk Likelihood	Impact	Overall Risk
SIS	High	High	High
Payment Portal	High	High	High
LMS	Medium	High	High
Website	Medium	Medium	Medium
Staff Portals	Medium	High	High

- ❖ **OCTAVE Allegro helps NSBM to organize its risk assessment around the digital resources that are vital to its operations. Thanks to this method, security experts can pinpoint critical risks and make smart plans for protection during future stages.**

7.4 Mitigation Plan.

Asset	Identified Threat	Mitigation Strategy	Responsible Team
Student Information System (SIS)	Relying on phishing tricks with staff social media (e.g., LinkedIn, Instagram)	Teach staff about secure practices regularly and always enable multi-factor and role-based access security.	IT Security & HR
Online Payment Portal	Stopping financial data exposure with Google Dorking involves segmenting networks	installing web application firewalls (WAF) and supervising the logs of access to your site	Network & Security Team
NSBM LMS	Spoofing because SPF/DKIM/DMARC are missing from your DNS records Apply SPF/DKIM/DMARC	change DNS configurations, watch for unusual activity	System Admin Team
NSBM Website (WordPress)	Regularly, you should install updated plugins	cover metadata and use secure WordPress configs.	Web Development Team
Staff Portals	Credential harvesting from login pages	Apply MFA, secure login portals, implement anti-bot protections	Cybersecurity Team

- ❖ **These mitigation methods were built according to the risks that appeared using the OCTAVE Allegro methodology. All actions are meant to minimize the chances and consequences of threats against NSBM's key assets. When NSBM uses technical tools together with organizational ones like security awareness training and providing access only to those who need it, it can improve its cybersecurity and keep its business running. The company assigns teams and sets dates to ensure every phase is met as planned and properly executed.**

7.5 Allegro Worksheets

Allegro Worksheet 1	RISK MEASUREMENT CRITERIA – REPUTATION AND CUSTOMER CONFIDENCE		
Impact Area	Low	Moderate	High
<i>Reputation</i>	Reputation is minimally affected; little or no effort or expense is required to recover.	Reputation is damaged, and some effort and expense are required to recover.	Reputation is irrevocably destroyed or damaged.
<i>Customer Loss</i>	Less than 5% reduction in customers due to loss of confidence	5% to 20% reduction in customers due to loss of confidence	More than 20% reduction in customers due to loss of confidence
<i>Other:</i>	Slight delay in publication of academic info; minor impact on public view	Temporary loss of stakeholder confidence; short-term drop in engagement	Loss of institutional ranking or reputation in national/international ratings

Allegro Worksheet 2	RISK MEASUREMENT CRITERIA – FINANCIAL		
Impact Area	Low	Moderate	High
<i>Operating Costs</i>	Increase of less than 5% in yearly operating costs.	Yearly operating costs increase by 5% to 15%.	Yearly operating costs increase by more than 15%.
<i>Revenue Loss</i>	Less than 5% yearly revenue loss	5% to 20% yearly revenue loss	Greater than 20% yearly revenue loss
<i>One-Time Financial Loss</i>	One-time financial cost of less than LKR 1,000,000	One-time financial cost of LKR 1,000,000 to LKR 5,000,000	One-time financial cost greater than LKR 5,000,000
<i>Other:</i>	Minor costs for password resets or user support requests	Costs for retraining staff and deploying monitoring tools	Indirect costs like third-party audits, PR crisis management, legal consulting fees

Allegro Worksheet 3		RISK MEASUREMENT CRITERIA – PRODUCTIVITY		
Impact Area	Low	Moderate	High	
Staff Hours	Staff work hours are increased by less than 5% for 1 to 2 days	Staff work hours are increased between 5% and 15% for 3 to 5 days(s).	Staff work hours are increased by greater than 15% for more than 5 days.	
Administrative Delays	Minor delays in record access with minimal manual validation needed	Delays in accessing student data, requiring manual correction and validation	Major system issues requiring manual re-entry of large data volumes over many days	
Academic Scheduling	Slight delay in releasing results or schedules	Course adjustments and rescheduling due to data inconsistency or access loss	Exam or semester planning significantly impacted, requiring academic calendar revision	
IT Staff Load	Small increase in workload to verify system integrity	Increased response and remediation work from IT security teams	Full deployment of incident response plan; system-wide audits and patching cycles	

Allegro Worksheet 4	RISK MEASUREMENT CRITERIA – SAFETY AND HEALTH		
Impact Area	Low	Moderate	High
<i>Life</i>	No loss or significant threat to customers' or staff members' lives	Customers' or staff members' lives are threatened, but they will recover after medical treatment	Loss of customers' or staff members' lives
<i>Health</i>	Minimal, immediately treatable degradation in staff stress or workload health impacts	Temporary or recoverable impairment of health	Permanent impairment of significant aspects of health
<i>Safety</i>	Safety questioned due to indirect stress/workload impact	Safety affected	Safety violated
<i>Psychological Well-being</i>	Temporary anxiety or distress among staff and students during breach incident	Sustained stress or reputational fear among staff/students over repeated incidents	No long-term psychological trauma expected

Allegro Worksheet 5		RISK MEASUREMENT CRITERIA – FINES AND LEGAL PENALTIES		
Impact Area	Low	Moderate	High	
Fines	Fines less than LKR 1,000,000 are levied.	Fines between LKR 1,000,000 and LKR 5,000,000 are levied.	Fines greater than LKR 5,000,000 are levied.	
Lawsuits	Non-frivolous lawsuits or lawsuits less than LKR 1,000,000 are filed against the organization, or frivolous lawsuit(s) are filed.	Non-frivolous lawsuits or lawsuits between LKR 1,000,000 and LKR 5,000,000.	Non-frivolous lawsuits or lawsuits greater than LKR 5,000,000 are filed.	
Investigations	No queries from government or other investigative organizations	Government or agency requests information or records (low profile).	The government or agency initiates a high-profile, in-depth investigation into practices.	
Other:	–	–	–	

Allegro Worksheet 6		IMPACT AREA PRIORITIZATION WORKSHEET
PRIORITY	IMPACT AREAS	
1	Financial - Total ALE exceeds LKR 100 million/year.	
2	Reputation and Customer Confidence - Loss of public trust in academia is highly damaging.	
3	Fines and Legal Penalties - High risk of legal non-compliance under data protection law.	
4	Productivity - Loss of access to LMS or SIS disrupts academic flow.	
5	Safe and Health - Though unlikely, phishing or fraud could endanger wellbeing indirectly.	

Allegro Worksheet 7		CRITICAL INFORMATION ASSET PROFILE	
(1) Critical Asset <i>What is the critical information asset?</i>		(2) Rationale for Selection <i>Why is this information asset important to the organization?</i>	(3) Description <i>What is the agreed-upon description of this information asset?</i>
Student Information System (SIS)		Contains sensitive student data (e.g., grades, personal details). Breach could lead to legal penalties and reputational damage.	Centralized database for student records, accessible to authorized staff.
Online Payment Portal		Handles financial transactions. Exploitation could result in direct financial loss.	Web-based system for tuition and fee payments, integrated with banking systems.
NSBM Learning Management System (LMS)		Hosts course materials and student submissions. Disruption could affect academic operations.	Cloud-hosted platform for online learning and assessments.
Official NSBM Website (WordPress CMS)		Public-facing site; metadata exposure could reveal vulnerabilities.	Primary digital interface for the university, hosted on AWS.
Staff Login Portals		Unauthorized access could lead to data breaches or system compromises.	Internal systems for staff communication and administrative tasks.
(4) Owner(s) <i>Who owns this information asset?</i>			
NSBM IT Department and Academic Administration jointly own and manage these assets.			
(5) Security Requirements <i>What are the security requirements for this information asset?</i>			

☐ Confidentiality	Only authorized personnel can view this information asset, as follows:	• This is only accessible to logged-in users, for example, system administrators, teachers, and staff members with specific roles. • Only the individual student's personal details are visible by logging in securely.	
☐ Integrity	Only authorized personnel can modify this information asset, as follows:	• Only certain positions, like administrators or heads of departments, have the authority to change. • Changes to records are monitored, audited, and verified by users. • System includes integrity and validation checks to protect against unauthorized changes.	
☐ Availability	This asset must be available for these personnel to do their jobs, as follows:	• The system must be available for use by staff within office hours and by students during the registration and examination periods. • We must maintain low downtime to avoid service disruptions.	
	This asset must be available for 16 hours, 6 days/week, 48 weeks/year.	—	
☐ Other	This asset has special regulatory compliance protection requirements, as follows:	Compliance with GDPR and local data protection laws.	
(6) Most Important Security Requirement			
<i>What is the most important security requirement for this information asset?</i>			
☒ Confidentiality	☐ Integrity	☐ Availability	☐ Other

Allegro - Worksheet 8		INFORMATION ASSET RISK WORKSHEET		
Information Asset Risk	Information Asset	Student Information System (SIS)		
	Area of Concern	Unauthorized access via phishing targeting staff credentials		
	(1) Actor <i>Who would exploit the area of concern or threat?</i>	Cybercriminals or threat actors exploiting staff members' credentials through phishing emails.		
	(2) Means <i>How would the actor do it? What would they do?</i>	Spear-phishing emails mimicking university communication channels to trick staff into revealing login credentials.		
	(3) Motive <i>What is the actor's reason for doing it?</i>	Financial gain through identity theft, data sales, or extortion; or reputational sabotage.		
	(4) Outcome <i>What would be the resulting effect on the information asset?</i>	✓ Disclosure		
		✓ Modification		
	(5) Security Requirements <i>How would the information asset's security requirements be breached?</i>	Confidentiality and Integrity would be breached potentially exposing student data and potentially altering them.		
	(6) Probability <i>What is the likelihood that this threat scenario could occur?</i>	✓ High	Medium	Low
	(7) Consequences <i>What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?</i>	(8) Severity <i>How severe are these consequences to the organization or asset owner by impact area?</i>		
	Impact Area	Value	Score	
Loss of student trust	Reputation & Customer	High	3	
	Financial	High	3	
Damage to institutional reputation	Productivity	Moderate	2	
	Safety & Health	Low	1	
Legal and regulatory penalties	Fines & Legal Penalties	High	3	
	User Defined Impact Area	-	-	
Relative Risk Score			12	

Allegro - Worksheet 8		INFORMATION ASSET RISK WORKSHEET				
Information Asset Risk	Threat	Information Asset	University Email System			
		Area of Concern	Spoofed university email domain used to send fake emails			
		(1) Actor <i>Who would exploit the area of concern or threat?</i>	Attackers impersonating internal NSBM staff or departments			
		(2) Means <i>How would the actor do it? What would they do?</i>	Forged email headers exploiting missing SPF/DKIM/TXT records			
		(3) Motive <i>What is the actor's reason for doing it?</i>	Data theft, malware delivery, credential harvesting			
		(4) Outcome <i>What would be the resulting effect on the information asset?</i>	☒ Disclosure ☒ Unauthorized access			
		(5) Security Requirements Authenticity and confidentiality of communications	Authenticity and confidentiality of communications			
	(6) Probability Medium	High	☒ Medium	Low		
	(7) Consequences Email trust	(8) Severity <i>How severe are these consequences to the organization or asset owner by impact area?</i>				
		Impact Area	Value	Score		
Malware infection	Reputation & Customer	Moderate	2			
	Financial	Moderate	2			
Data leaks	Productivity	Moderate	2			
	Safety & Health	Low	1			
	Fines & Legal	Moderate	2			
	User Defined Impact Area	-	-			
Relative Risk Score				9		

Allegro - Worksheet 8		INFORMATION ASSET RISK WORKSHEET				
Information Asset Risk	Threat	Information Asset	NSBM Public Website (CMS)			
		Area of Concern	Exploitation via visible metadata, outdated plugins			
		(1) Actor Hackers scanning CMS footprints and version data	Cybercriminals or threat actors exploiting staff members' credentials through phishing emails.			
		(2) Means Using directory listing, plugin vulnerabilities	Spear-phishing emails mimicking university communication channels to trick staff into revealing login credentials.			
		(3) Motive Website defacement, SEO spam, malicious redirects	Financial gain through identity theft, data sales, or extortion; or reputational sabotage.			
		(4) Outcome	☒ Modification ☒ Service disruption			
		(5) Security Requirements <i>How would the information asset's security requirements be breached?</i>	Availability, integrity			
	(6) Probability <i>What is the likelihood that this threat scenario could occur?</i>	High	☒ Medium	Low		
	(7) Consequences Site downtime	(8) Severity <i>How severe are these consequences to the organization or asset owner by impact area?</i>				
			Impact Area	Value	Score	
Defacement	Reputation & Customer	Moderate	2			
	Financial	Low	1			
Reputational damage	Productivity	Moderate	2			
	Safety & Health	Low	1			
	Fines & Legal Penalties	Low	1			
	User Defined Impact Area	-	-			
Relative Risk Score					7	

Allegro - Worksheet 8		INFORMATION ASSET RISK WORKSHEET			
Information Asset Risk	Threat	Information Asset	Login Portals (LMS, Staff Dashboards)		
		Area of Concern	Searchable login pages may expose credentials		
		(1) Actor Hackers scanning CMS footprints and version data	Attackers using search engines (Google Dorking)		
		(2) Means Using directory listing, plugin vulnerabilities	site:nsbm.ac.lk inurl:login + brute force / phishing		
		(3) Motive Website defacement, SEO spam, malicious redirects	Unauthorized access, privilege escalation		
		(4) Outcome	✓ Modification		
			✓ Unauthorized control		
	(5) Security Requirements <i>How would the information asset's security requirements be breached?</i>	Authentication, confidentiality			
	(6) Probability <i>What is the likelihood that this threat scenario could occur?</i>	✓ High	Medium	Low	
	(7) Consequences User impersonation	(8) Severity <i>How severe are these consequences to the organization or asset owner by impact area?</i>			
	Impact Area	Value	Score		
Data compromise	Reputation & Customer	High	3		
	Financial	Moderate	2		
	Productivity	Moderate	2		
	Safety & Health	Low	1		
	Fines & Legal Penalties	Moderate	2		
	User Defined Impact Area	-	-		
			Relative Risk Score	10	

Allegro - Worksheet 8		INFORMATION ASSET RISK WORKSHEET			
Information Asset Risk	Threat	Information Asset	Internal Staff Systems, Wi-Fi, Data Access		
		Area of Concern	Unauthorized use or leak of internal data by staff/student		
		(1) Actor Hackers scanning CMS footprints and version data	Disgruntled staff, careless users		
		(2) Means Using directory listing, plugin vulnerabilities	Unauthorized access, copying data, bypassing controls		
		(3) Motive Website defacement, SEO spam, malicious redirects	Revenge, money, or carelessness		
		(4) Outcome	✓ Disclosure		
			✓ Disruption		
	(5) Security Requirements <i>How would the information asset's security requirements be breached?</i>	Confidentiality, access control			
	(6) Probability <i>What is the likelihood that this threat scenario could occur?</i>	High	✓ Medium	Low	
	(7) Consequences Data misuse	(8) Severity <i>How severe are these consequences to the organization or asset owner by impact area?</i>			
	Impact Area	Value	Score		
Trust loss	Reputation & Customer	High	3		
	Financial	Moderate	2		
Academic integrity damage	Productivity	Moderate	2		
	Safety & Health	Low	1		
	Fines & Legal Penalties	Moderate	2		
	User Defined Impact Area	-	-		
Relative Risk Score			10		

Information Asset	Relative Risk Score
Student Information System (SIS)	12
University Email System	9
NSBM Public Website (CMS)	7
Login Portals (LMS, Staff Dashboards)	10
Internal Staff Systems, Wi-Fi, Data Access	10
Relative Risk Total Score	48

(9) Risk Mitigation

Based on the total score for this risk, what action will you take?

☐ Accept	☐ Defer	☐ Mitigate	☐ Transfer
For the risks that you decide to mitigate, perform the following:			
<i>On what container would you apply controls?</i>	<i>What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?</i>		
SIS (Student Information System) Web Application	Administrative Controls: Regular staff cybersecurity training on phishing and credential security. Technical Controls: Multi-Factor Authentication (MFA), role-based access control, phishing email filters, network segmentation, and encryption of student records. Physical Controls: Restricted physical access to servers and staff terminals. Residual Risk: Minimal residual risk from advanced social engineering or insider threats that bypass MFA.		
Email Server (connected to SIS access)	Administrative Controls: Email use policies and periodic awareness campaigns. Technical Controls: SPF, DKIM, and DMARC DNS records to reduce email spoofing; email logging and anomaly detection. Residual Risk: Some chance of new phishing strategies evading filters.		
User Endpoints (staff computers)	Administrative Controls: Acceptable use policy enforcement. Technical Controls: Anti-malware software, endpoint protection tools, browser sandboxing. Physical Controls: Locked workstations when unattended. Residual Risk: Device misuse by insiders or lost/stolen hardware.		
Authentication System	Technical Controls: Enforced password complexity policies, periodic password changes, MFA. Residual Risk: Brute-force attempts on low-value accounts.		
Network Infrastructure	Technical Controls: Web Application Firewall (WAF), Intrusion Detection System (IDS), network monitoring. Residual Risk: Temporary downtime due to zero-day exploits or DDoS attacks.		

8.0 Quantitative Risk Assessment Using ALE & SLE

Cyber-attacks in the educational industry are a widespread threat to all kinds of institutes. NSBM university was found to be vulnerable for 5 main types of attacks. The impact that these vulnerabilities can cause, along with the damage it can cause is done via a quantitative risk assessment below. The areas of impact and the vulnerabilities have been discussed in chapter 4.4

8.1 Phishing

Calculation of SLE and ALE for Phishing at NSBM

- $SLE = AV \times EF$
= LKR 30,000,000 $\times$ 0.4
= **LKR 12,000,000**
- $ALE = SLE \times ARO$
= LKR 12,000,000 $\times$ 3 (successful phishing attacks per year)
= **LKR 36,000,000**

Real world examples:

- Cyberattack on Edinburgh department (Stewart, 2025)
- PowerSchool data breach (Raymond, 2025)
- Lumma Infostealer Malware Takedown (Newman & Burgess, 2025)

8.2 Email Spoofing.

Calculation SLE and ALE for Email Spoofing at NSBM

- $SLE = AV \times EF$
 $= \text{LKR } 15,000,000 \times 0.6$
 $= \text{LKR } 9,000,000$
- $ALE = SLE \times ARO$
 $= \text{LKR } 9,000,000 \times 2 \text{ (successful spoofing attacks per year)}$
 $= \text{LKR } 18,000,000$

Real world examples:

- Edinburgh Education Department Email Spoofing (Stewart, 2025)
- Education sector cyberattacks report (Kelley, 2024)
- Phishing targeting higher education (Pearson, et al., 2025)

8.3 Website Exploitation.

Calculation of SLE and ALE for Website Exploitation at NSBM

- $SLE = AV \times EF$
 $= \text{LKR } 22,500,000 \times 0.5$
 $= \text{LKR } 11,250,000$
- $ALE = SLE \times ARO$
 $= \text{LKR } 11,250,000 \times 1.5 \text{ (successful exploitation attacks per year)}$
 $= \text{LKR } 16,875,000$

Real world examples:

- Biggest Education Industry Attacks in 2024 (SOCRadars, 2024)
- Cyber Security in Education Sector (ACID Technologies, n.d.)
- Improving Critical Infrastructure Cybersecurity (Anon., 2018)

8.4 Credential theft via Google Dorking.

Calculation of SLE and ALE for Credential Theft via Google Dorking at NSBM

- $SLE = AV \times EF$
= LKR 18,000,000 $\times$ 0.6
= **LKR 10,800,000**
- $ALE = SLE \times ARO$
= LKR 10,800,000 $\times$ 1.5 (successful credential theft attacks per year)
= **LKR 16,200,000**

Real world examples:

- PowerSchool data breach (Roth, 2025)
- Potential Data Breach (Khan, 2024)
- Education Sector Breaches (Kelley, 2024)

8.5 Insider Threats.

Calculation of SLE and ALE for Insider Threats at NSBM

- $SLE = AV \times EF$
= LKR 24,000,000 $\times$ 0.5
= **LKR 12,000,000**
- $ALE = SLE \times ARO$
= LKR 12,000,000 $\times$ 1.2 (successful insider threat attacks per year)
= **LKR 14,400,000**

Real world examples:

- Public Wi-Fi Vulnerabilities in Educational Institutions (Underdown, 2024)
- Inadequate Role-Based Access Controls (Infinity Network Solutions, n.d.)
- Human Error and Misconfigurations (Wolf, 2024)

8.6 Total Annual Loss Expectancy (ALE)

Threat	ALE
Phishing	LKR 36,000,000
Email Spoofing	LKR 18,000,000
Website Exploitation	LKR 16,875,000
Credential Theft (Google Dorking)	LKR 16,200,000
Insider Threats	LKR 14,400,000
TOTAL	LKR 101,475,000

- Total Potential Annual Loss = LKR 96,300,000
- This makes a strong case for immediate and prioritized investment in:
 - Employee training (anti-phishing & insider threats)
 - DNS and email authentication (SPF, DKIM, DMARC)
 - Web application security and patching
 - Search engine hardening (robots.txt, portal masking)
 - Network access control and secure public Wi-Fi policies

9.0 Overall Assessment.

In this report, various passive methods and industry standards were used to analyze and simulate the cybersecurity situation of NSBM Green University. Learning activities in this stage made it possible to find a variety of weaknesses in systems and settings that make them easy targets for cybercriminals, including metadata disclosures, unprotected access portals, missing records in DNS settings and noticeably public information about company personnel.

With the OCTAVE Allegro framework, we found the key digital assets for NSBM and sorted the threats by how much they might damage the business. Steps were taken to guard against these risks, including setting up firewalls, doing multi-factor authentication and teaching employees about proper security.

Additionally, a detailed plan was created based on ISO/IEC 27001, relating risks to suitable international control procedures. With the help of ALE and SLE, quantitative risk analysis revealed possible losses of over LKR 96 million each year, urging the company to focus on cybersecurity and keep improving.

The findings allow NSBM to address its academic challenges and help the company decrease weaknesses, meet regulations and strengthen its defense against cyber threats. This way, NSBM can ensure that academic processes, digital tools and the trust placed in it are properly protected.

10.0 References

- 1) ACID Technologies, n.d. *Cybersecurity for education*. [Online]
Available at: <https://www.acid-tech.com/solutions/cyber-security-in-education-sector/>
[Accessed 23 May 2025].
- 2) Alanna Titterington, 2025. *Email from Google: law enforcement is looking into your account*. [Online]
Available at: <https://www.kaspersky.com/blog/dkim-replay-attack-through-google-oauth/53392/>
[Accessed 07 May 2025].
- 3) Anon., 2018. *Framework for Improving Critical Infrastructure Cybersecurity*, s.l.: National Institute of Standards and Technology.
Anon., 2022. *Information security, cybersecurity and privacy protection*. [Online]
Available at: <https://www.iso.org/obp/ui/en/#iso:std:82875:en>
[Accessed 22 May 2025].
- 4) Anon., 2025. *Bitsight*. [Online]
Available at: <https://www.bitsight.com/glossary/cybersecurity-reconnaissance>
[Accessed 17 May 2025].
- 5) Anon., 2025. *Reconnaissance*. [Online]
Available at: <https://www.blumira.com/glossary/reconnaissance>
[Accessed 29 03 2025].
- 6) Caralli, R. A., Stevens, J. F., Young, L. R. & Wilson, W. R., 2007. *Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process*. [Online]
Available at: <https://insights.sei.cmu.edu/library/introducing-octave-allegro-improving-the-information-security-risk-assessment-process/>
[Accessed 21 May 2025].
- 7) Google Workspace Admin, n.d. *Google Workspace Admin Help*. [Online]
Available at: <https://support.google.com/a/answer/33786?hl=en>
[Accessed 21 May 2025].lam

8) Infinity Network Solutions, n.d. *The 5 Biggest Cyber Threats For the Education Sector in 2024*. [Online]

Available at: <https://infinitynetwork.com/the-5-biggest-cyber-threats-for-the-education-sector-in-2024/>

[Accessed 23 May 2025].

9) IT Governance, n.d. *IT Governanace*. [Online]

Available at: <https://www.itgovernance.co.uk/iso27001-2022-controls>

[Accessed 21 May 2025].

10) Kelley, D., 2024. *Abnormal Blog*. [Online]

Available at: <https://abnormal.ai/blog/education-sector-august-2024-cyberattacks>

[Accessed 23 May 2025].

11) Khan, A., 2024. *Uncovering Security Flaws in IT Management Portal Through Google Dorking*. [Online]

Available at: <https://medium.com/%40k45arbaz/google-dorking-potential-data-breach-and-ad-compromise-0c34ab868b6e>

[Accessed 23 May 2025].

12) Lindiwe Matlali, 2023. *World Economic Forum*. [Online]

Available at: <https://www.weforum.org/stories/2023/06/cybersecurity-and-ai-challenges-opportunities/>

[Accessed 17 May 2025].

13) Melissa Hawkins, n.d. *Big Star Copywriting*. [Online]

Available at: <https://www.bigstarcopywriting.com/blog/content-marketing/what-is-website-meta-data/>

[Accessed 17 May 2025].

14) National Institute of Standards and Technology, 2018. *NIST*. [Online]

Available at: <https://www.nist.gov/cyberframework>

[Accessed 22 May 2025].

- 15) Newman, L. H. & Burgess, M., 2025. *WIRED*. [Online]
Available at: <https://www.wired.com/story/lumma-stealer-takedown-disrupted/>
[Accessed 23 May 2025].
- 16) Pearson, A. et al., 2025. *Google Cloud*. [Online]
Available at: <https://cloud.google.com/blog/topics/threat-intelligence/phishing-targeting-higher-education>
[Accessed 23 May 2025].
- 17) Raymond, N., 2025. *Reuters*. [Online]
Available at: <https://www.reuters.com/legal/massachusetts-hacker-plead-guilty-powerschool-data-breach-2025-05-20/>
[Accessed 23 May 2025].
- 18) Richard A. Caralli, J. F. S. L. R. Y. W. R. W., 2007. *Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process*. [Online]
Available at: <https://insights.sei.cmu.edu/library/introducing-octave-allegro-improving-the-information-security-risk-assessment-process/>
[Accessed 21 May 2025].
- 19) Roth, E., 2025. *19-year-old student to plead guilty to huge school database hack*. [Online]
Available at: <https://www.theverge.com/news/671713/powerschool-hack-guilty-plea-matthew-lane>
[Accessed 23 May 2025].
- 20) SOCRadar, 2024. *Biggest Education Industry Attacks in 2024*. [Online]
Available at: <https://socradar.io/biggest-education-industry-attacks-in-2024/>
[Accessed 23 May 2025].
- 21) Stewart, C., 2025. *The Sunday Times*. [Online]
Available at: https://www.thetimes.com/article/cyberattack-on-edinburgh-education-department-causes-exam-revision-chaos-2fnwcrvmt?utm_source=chatgpt.com
[Accessed 23 May 2025].

22) Underdown, K., 2024. *Guest Wi-Fi vs. Regular Wi-Fi vs. Public Wi-Fi:*

Understanding the Differences To Protect Your Data. [Online]

Available at: <https://www.dnsfilter.com/blog/guest-vs-regular-vs-public-wifi/>

[Accessed 23 May 2025].

23) Wolf, A., 2024. *10 Cybercrimes Against Colleges and K-12 Schools, and How To Prevent Them.* [Online]

Available at: <https://arcticwolf.com/resources/blog/cyber-attacks-against-schools-and-colleges/>

[Accessed 23 May 2025].

24) WordPress Developer Resources, 2023. *Hardening WordPress.* [Online]

Available at: <https://developer.wordpress.org/advanced-administration/security/hardening/>

[Accessed 22 May 2025].

25) Zehra Ali, 2023. *Infosecurity Magazine.* [Online]

Available at: <https://www.infosecurity-magazine.com/next-gen-infosec/social-media-phishing-threat/>

[Accessed 17 May 2025].